

Guía Metodológica de la Encuesta AMPARO-ENS

Uso de Indicadores y Métricas para el Diagnóstico de Ciberseguridad

1. Propósito de la encuesta

La encuesta AMPARO-ENS tiene como finalidad:

- Diagnosticar el grado de adecuación al Esquema Nacional de Seguridad (ENS) en organizaciones públicas y privadas que se relacionan con el sector público.
- Medir, de forma homogénea, indicadores clave alineados con las guías CCN-STIC-815 (Métricas e Indicadores) y CCN-STIC-824 (Informe del Estado de Seguridad). [web:32][web:33][web:35][web:38]
- Comprender cómo se utilizan las herramientas INES y AMPARO como instrumentos de gobernanza y planificación. [web:21][web:39]
- Integrar la visión de riesgo, Zero Trust, ciberresiliencia y gestión de recursos en un cuadro coherente y explotable.

Todo ello con un espíritu propositivo: no se trata de poner notas, sino de producir una radiografía útil para priorizar, persuadir y planificar.

2. Población objetivo y unidades de análisis

•

Población objetivo:

Entidades sujetas al ENS o que, sin estar formalmente obligadas, prestan servicios al sector público o gestionan servicios críticos. [web:21][web:30]

•

Unidad de análisis:

La organización como entidad jurídica (ministerio, consejería, ayuntamiento, empresa pública, empresa privada proveedora, etc.). En entornos muy descentralizados, se podrá replicar la encuesta por unidad organizativa relevante.

•

Respondentes recomendados:

CISO, CIO, responsable ENS, responsable de riesgos/seguridad, con acceso a información transversal. Se aconseja coordinación interna para evitar respuestas fragmentarias.

Población objetivo:

Entidades sujetas al ENS o que, sin estar formalmente obligadas, prestan servicios al sector público o gestionan servicios críticos. [web:21][web:30]

Unidad de análisis:

La organización como entidad jurídica (ministerio, consejería, ayuntamiento, empresa pública, empresa privada proveedora, etc.). En entornos muy descentralizados, se podrá replicar la encuesta por unidad organizativa relevante.

Respondentes recomendados:

CISO, CIO, responsable ENS, responsable de riesgos/seguridad, con acceso a información transversal. Se aconseja coordinación interna para evitar respuestas fragmentarias.

3. Diseño del cuestionario

La estructura del cuestionario se inspira en los componentes ENS y en la lógica de métricas de la guía CCN-STIC-815: datos → métricas → indicadores → decisiones. [web:32][web:35]

Los bloques principales son:

1. Información general: contexto mínimo para interpretar resultados (tipo de entidad, tamaño, sector).
2. Gobierno y cumplimiento ENS: políticas, órganos de decisión, uso de INES y AMPARO, DA, perfiles de cumplimiento. [web:21][web:33][web:39]
3. Riesgo, Zero Trust y criptografía: análisis de riesgos, MFA, segmentación, verificación continua, cifrado, preparación post-cuántica. [web:2][web:11][web:15][web:38]
4. Operación, incidentes y ciberresiliencia: gestión de incidentes, monitorización, SOC, continuidad, simulacros. [web:25][web:6][web:33]
5. Recursos y cultura: presupuesto, personal, formación, concienciación, cultura de seguridad. [web:8][web:13][web:6]
6. Métricas y uso de la información: cuadros de mando, tipos de métricas, integración con planificación e informes ejecutivos. [web:32][web:33]
7. Visión futura: prioridades y barreras, como complemento cualitativo.

Dentro de cada bloque, se utilizan principalmente preguntas cerradas, con escalas categóricas y opciones diseñadas para permitir análisis comparables, evitando el síndrome de “todo está bien” propio de las autoevaluaciones complacientes.

4. Escalas de medida y codificación

Para facilitar el análisis:

- Las respuestas dicotómicas (sí/no) se codificarán como 1 (sí) y 0 (no).
- Las escalas ordinales (por ejemplo, grado de implantación) se codificarán en valores crecientes (1, 2, 3, 4...) que reflejen mayor madurez o cumplimiento.
- Las opciones “No sabe / No responde” se codificarán como valor perdido (NA), pero contabilizables para inferir incertidumbre o falta de gobernanza.

Se recomienda documentar en un diccionario de datos:

- Código de cada pregunta (por ejemplo, GOB_1_1, RISK_2_3, INC_3_2, etc.).
- Tipo de variable (nominal, ordinal, binaria).
- Codificación numérica.
- Referencia normativa ENS/CCN-STIC asociada (ver documento de mapeo).

5. Indicadores sintéticos: IGM y otros índices

La encuesta está pensada para alimentar, al menos, los siguientes indicadores:

- IGM (Índice Global de Madurez ENS):
Agregado ponderado de preguntas clave de gobierno, cumplimiento, riesgo, operación, ciberresiliencia y cultura.
- Se recomienda una escala de 0 a 100.
- Cada bloque puede tener una puntuación parcial, permitiendo comparaciones intra-organización e inter-organizaciones.
- Indicadores específicos ENS (alineados con CCN-STIC-815 y 824): [web:32][web:33]
- % de medidas ENS implantadas (percepción/realidad).
- Nivel de uso efectivo de INES/AMPARO. [web:21][web:39]
- Grado de institucionalización de análisis de riesgos.
- Madurez de gestión de incidentes y continuidad.
- Cobertura de MFA, cifrado, monitorización.
- Indicadores de ciberresiliencia:
- Existencia de BCP/DRP y pruebas.
- Integración de ciberseguridad en la gestión de crisis.
- Medición de RTO/RPO y su cumplimiento.

Cada bloque puede tener una puntuación parcial, permitiendo comparaciones intra-organización e inter-organizaciones.

Indicadores específicos ENS (alineados con CCN-STIC-815 y 824): [web:32][web:33]

Cobertura de MFA, cifrado, monitorización.

Indicadores de ciberresiliencia:

Estos indicadores se calculan usando la plantilla propuesta para Excel (ver documento correspondiente).

6. ROI de ciberseguridad y uso estratégico de resultados

Aunque el ROI en ciberseguridad es conceptualmente esquivo, la encuesta permite aproximarse a él desde tres ángulos:

8. Reducción de riesgo esperado:
9. Mejoras en indicadores de control se traducen, en marcos actuariales, en reducción de probabilidad/impacto de incidentes.
10. Eficiencia operacional:
11. Mayor madurez en procesos reduce tiempos de detección, respuesta y recuperación, con impacto directo en costes.
12. Valor regulatorio y reputacional:
13. Cumplimiento ENS, NIS2 y marcos asociados reduce sanciones, conflictos contractuales y daños de imagen. [web:30][web:3]

El análisis de ROI debe hacerse con prudencia (y algo de humor autocrítico), pero no por ello dejar de intentarlo: la plantilla de Excel propone métricas que combinan costes y mejoras de indicadores.

7. Procedimiento de aplicación

7.1. Preparación

- Designar un coordinador interno de la encuesta (idealmente el CISO o responsable ENS).
- Revisar el cuestionario y adaptar, solo si es imprescindible, términos muy específicos al vocabulario local.
- Informar a los participantes del propósito y de la confidencialidad de los resultados.

7.2. Recogida de datos

- Se recomienda rellenar la encuesta de forma colaborativa (CISO, TI, riesgos, continuidad, RRHH, etc.).
- Es preferible sacrificar velocidad a cambio de veracidad: mejor una respuesta honesta en dos semanas que un “todo verde” en dos días.
- La encuesta puede realizarse en formato digital (formulario web, herramienta de encuestas) o en versión distribuida en plantilla.

7.3. Control de calidad

- Revisar consistencia de respuestas (por ejemplo, no tener “cifrado sistemático” y al tiempo “ausencia de políticas de cifrado”).
- Verificar que las preguntas más críticas para el IGM están respondidas.
- Documentar aclaraciones o matices importantes en comentarios adicionales.

8. Análisis y explotación

El análisis debe contemplar:

14. Resultados por bloque: gobierno, riesgo, operación, recursos, cultura, métricas.
15. Comparación con otras organizaciones del mismo tipo (tamaño, sector, administración vs. proveedor).
16. Identificación de huecos de cumplimiento ENS y prioridades de actuación.
17. Preparación de mensajes clave para la alta dirección:
18. 3 riesgos estructurales.
19. 3 fortalezas.
20. 3 decisiones recomendadas a corto/medio plazo.

La encuesta está diseñada para ser repetida (por ejemplo, anual o bianualmente), lo que permitirá observar tendencias y medir el progreso, no solo la foto fija.

9. Consideraciones éticas y de confidencialidad

- Los datos deben tratarse de acuerdo con la normativa de protección de datos y de seguridad de la información aplicable.
- En análisis agregados (por ejemplo, informes sectoriales), se recomienda anonimizar las entidades salvo consentimiento explícito.
- Cualquier publicación de resultados debe evitar clasificar públicamente a organizaciones concretas como “inseguras” sin contexto, por higiene profesional y por simple prudencia jurídica.

10. Limitaciones y posibles extensiones

Limitaciones inevitables:

- Dependencia de la autoevaluación: la percepción puede no coincidir con la realidad técnica.
- Diferencias de interpretación de ciertos términos, pese a los esfuerzos de estandarización.
- Evolución normativa (ENS, NIS2, otros marcos) que puede hacer necesaria una revisión periódica del cuestionario.

Posibles extensiones futuras:

- Módulos específicos por sector (salud, educación, justicia, etc.).
- Integración con datos objetivos (número real de incidentes, auditorías, sanciones).
- Cuestionarios complementarios para proveedores críticos (cadenas de suministro).

Mientras tanto, esta encuesta pretende ser un marco de referencia suficientemente robusto para dialogar con dirección, auditoría, reguladores y, por qué no, con la propia conciencia profesional del CISO.